

CSIT302 Cybersecurity

Day 5-4 – Security Policy

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Cybersecurity: Attacking and Defense

Cybersecurity Kill Chain

- External reconnaissance
- Compromising the system
- Lateral movement
- Privilege escalation
- Concluding the mission



- Security Policy
- Network Segmentation
- Active Sensor
- Recovery Process
- Vulnerability Management



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

What is a security policy?

- According to NIST special publications, there are several definitions of security policy:
 - A set of criteria for the provision of security services.
 - The statement of required protection for the information objects.
 - A set of rules that governs all aspects of security-relevant system and system component behaviours.
 - A set of rules that governs all aspects of security-relevant system and system element behaviour.
 - Security policies define the objectives and constraints for the security program.

Overview

- Reviewing security policy
- Educating end users
- Policy enforcement
- Monitoring for compliance

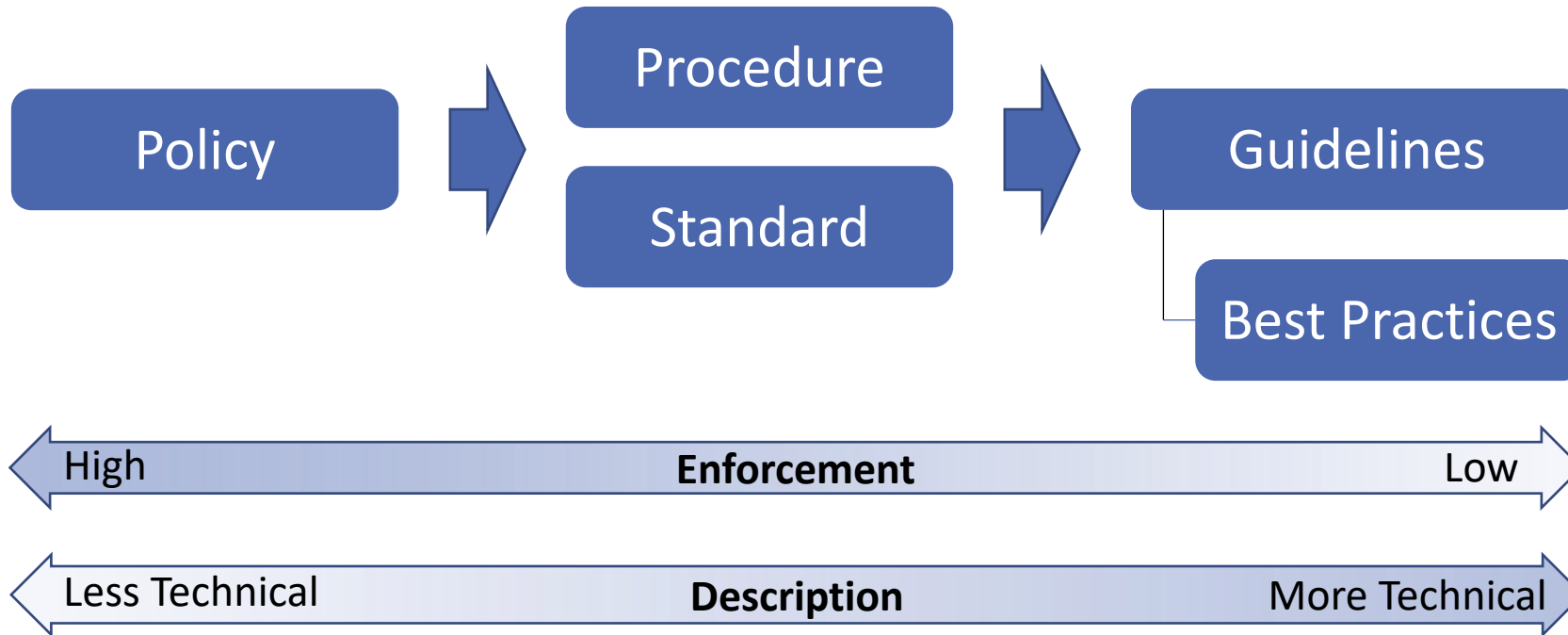
Reviewing Security Policy

- Questions regarding security policy
 - Do you even have a security policy in place?
 - Do you enforce this policy?
 - How often do you review this security policy, looking for improvements?
- Security policy is a living document - **it needs to be revised and updated, regularly or on-demand.**
- What security policies should include:
 - **industry standards, procedures, and guidelines:** These are necessary to support information risks in daily operations.
 - **Well-defined scope:** It must be stated in the scope section of the policy whether the policy applies to a certain group of people or everyone reading it including contractors.

Reviewing Security Policy

- The foundation of the security policy
 - Security policy should help protect the security triad (confidentiality, integrity, and availability).
- Requirements from users
 - Users are required to **protect and ensure the applicability of the security triad in the data and systems.**
 - Users must be aware of their responsibilities, and the **consequences of violating these policies.**

Reviewing Security Policy



Reviewing Security Policy

- Various documents involved in overall security policy (all users understand the difference between the following documents):
 - **Policy**
 - This is the basis of everything; it sets high-level expectations. It will also be used to guide decisions and achieve outcomes.
 - It is for all participants so it cannot be too technical.
 - It must be enforced by a proper authority.
 - **Procedure:**
 - As the name suggests, this is a document that has procedural steps that outline how something must be done.

Reviewing Security Policy

- **Standard:**

- This document establishes technical requirements that must be followed. In other words, everyone must comply with certain standards that were previously established.
- The standard document must provide enough technical details to give an accurate and detailed explanation of requirements to the relevant personals such as security engineers or security management officers.
- All requirements in the policy document must be covered in its associated standard documents if they need technical specifications.

Reviewing Security Policy

- **Guidelines:**

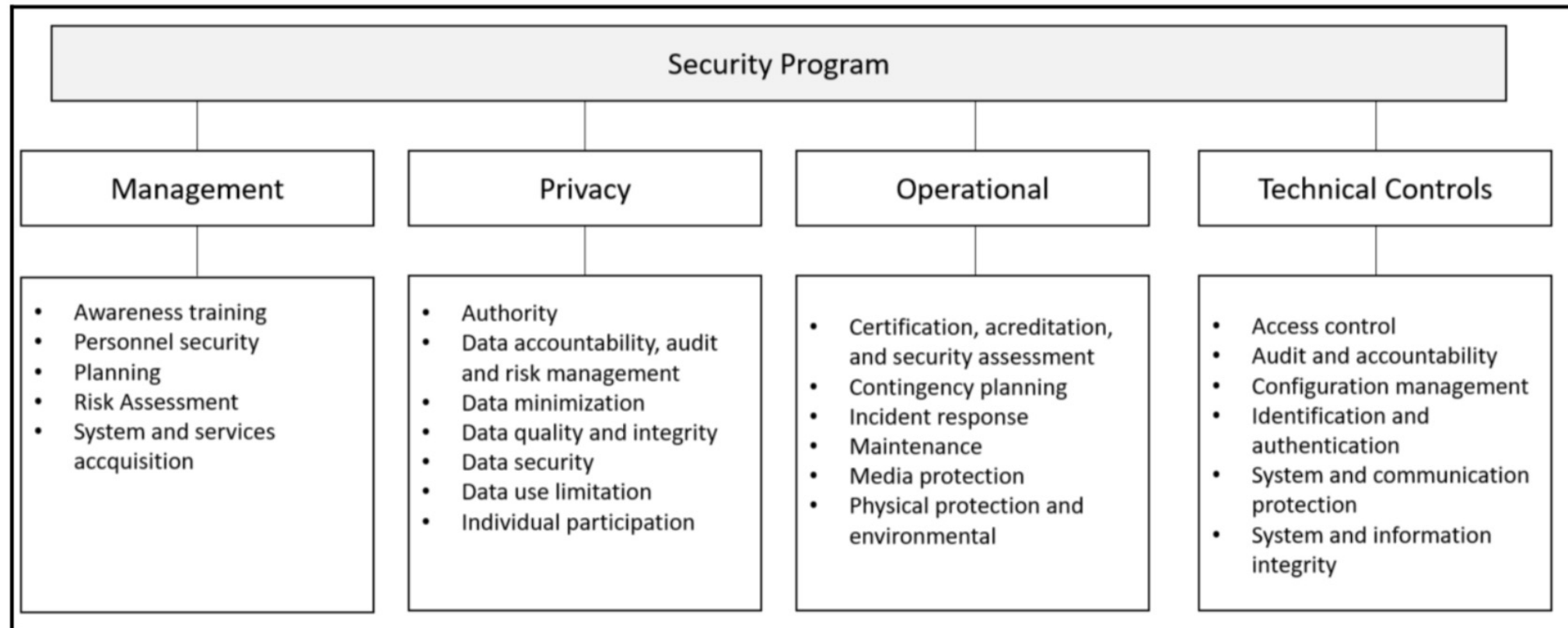
- Guidelines can be optional but can also be additional recommended guidance. Each company has the freedom to define whether the guidelines are optional, or if they are recommended.
- Guidelines must be aligned with the policy and standard documents. Guidelines are usually written to give more specific details with practical examples such as best practices.
- This can be used to guide someone who have substantial knowledge of Information technology, but is not specialized on cybersecurity domain.

Reviewing Security Policy

- **Best practices:**
 - These are best practices to be implemented by the entire company, or just some departments within the company.
 - This can also be established per role—for example, all web servers should have best security practices from the vendor applied prior to being deployed in production.
 - These can be a part of guidelines.
- To make sure that all these documents are synchronized, managed, and have the upper management sponsorship, an organization-wide security program is needed.

Reviewing Security Policy

- Example of an organization-wide security program: NIST SP 800-53 - <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-53r4.pdf>



Reviewing Security Policy

- What is NIST Special Publication (SP) 800?
 - *“Publications in NIST’s Special Publication (SP) 800 series present information of interest to the computer security community. The series comprises **guidelines, recommendations, technical specifications, and annual reports** of NIST’s cybersecurity activities.”*
- NIST SP 800-53
 - FIPS Publication 200, *Minimum Security Requirements for Federal Information and Information Systems*, is a **mandatory federal standard** developed by NIST in response to FISMA.
 - To comply with the federal standard, organizations apply the appropriately tailored set of baseline security controls in NIST Special Publication 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* in accordance with FIPS publication 200. Organizations have **flexibility** in applying the baseline security controls in accordance with the guidance provided in Special Publication 800-53.

UoW Cybersecurity Policy

- Let us have a look at the site and see how UOW define cybersecurity policy in <https://policies.uow.edu.au/document/view-current.php?id=67>
- Contents of the Policy include
 - Section 1 - Purpose of Policy
 - Section 2 – Application and Scope
 - Section 3 – Policy Principles
 - Section 4 - Roles and Responsibilities
 - Section 5 - Definitions

UoW Cybersecurity Policy

- **Section 1 - Purpose of Policy**

(1) This document sets out the University's policy on cyber security.

(2) Cyber security is about defending IT facilities and services and stored data from unauthorized access, use, disclosure, disruption, modification, and destruction. It seeks to ensure integrity, availability, confidentiality and safety of data and services; and ensures controls are proportionate to risk.

(3) This Policy is supported by a cyber security framework which includes supplementary policies; guidelines on specific topics; operational practices; action plans; technology controls; education programs and monitoring and assurance activities.

- **Section 2 - Application and Scope**

(4) This Policy applies to all users and devices of IT facilities and services at the University.

(5) All users should be aware of this Policy, their responsibilities, and legal obligations.

(6) All users and devices are required to comply with this Policy and are bound by law to observe applicable statutory legislation.

Top of Page

UoW Cybersecurity Policy

- Section 4 - Roles and Responsibilities

- Chief Information Digital Officer
- Cyber Security Team
- Risk, Audit and Compliance Committee
- Staff with responsibility for managing any IT Facility or Service
- Users of IT Facilities and Services

(14) Individual users have the following responsibilities for themselves and their devices:

- a. using IT facilities and services according to IT policies at all times;
- b. being aware of the security requirements of the IT facilities and services they use, and take every precaution to safeguard their access to these systems against unauthorized use; and
- c. immediately reporting any known or suspected security incidents and breaches to IMTS.

UoW Cybersecurity Policy

[Top of Page](#)

Section 5 - Definitions

Word/Term	Definition (with examples if required)
Cyber security	The practice of defending computing devices, networks and stored data from unauthorised access, use, disclosure, disruption, modification, or destruction
IMTS	Information Management & Technology Services at the University of Wollongong.
IT Facilities and Services	Information Technology facilities operated by or on behalf of the University. This includes services and systems and associated computing hardware and software used for the communication, processing, and storage of information
University	University of Wollongong and controlled entities
University network	The network infrastructure used by the University including all network services on main campus and satellite campuses with trusted access to UOW services
User	A person assigned a User Account by the University or a person who is otherwise authorised to use University IT Facilities and Services

UoW Cybersecurity Policy

- Now take a look at “IT SERVER SECURITY POLICY”.

<https://policies.uow.edu.au/document/view-current.php?id=69>

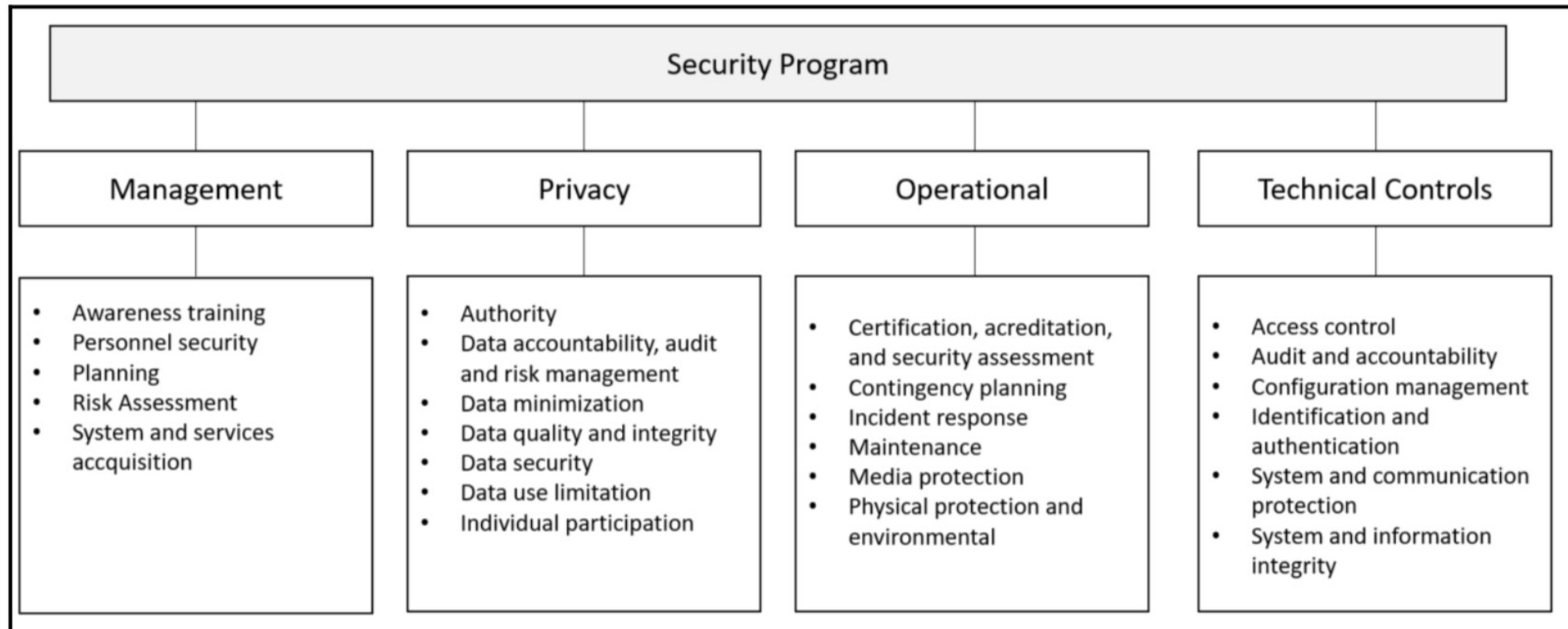
Section 2 - Application and Scope

[Top of Page](#)

- (2) This Policy applies to:
- a. servers that are connected to a University network;
 - b. servers that are operated for or on behalf of the University regardless of which network they are connected to; and
 - c. infrastructure as a service and platform as a service.
- (3) This Policy does not apply to services that are procured as the “software as a service”.

Reviewing Security Policy

- Example of an organization-wide security program: NIST SP 800-53 - <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-53r4.pdf>



Educating the End User

- Security awareness training
 - As shown in the diagram of NIST SP 800-53, the end user's education is part of the management control.
 - Perhaps this is one of the most important pieces of the security program, because **a user who is uneducated in security practices can cause tremendous damage to the organization.**
 - It should be delivered to all employees, and it should be constantly updated to include new attack techniques and considerations.
 - Many companies are delivering such training online, via the company's intranet. If the training is well-crafted, rich in visual capabilities, and contains a self-assessment at the end, it can be very effective.

Educating the End User

- Contents of the security awareness training:
 - **Real-world examples:** Users will more easily remember things if a real scenario is shown. For example, talking about phishing emails without showing what a phishing email looks like, and how to visually identify one, will not be very effective.
 - **Practice:** Well-written text and rich visual elements are important attributes in training materials, but the user must go through some practice. For example, the user can interact with the computer to identify spear phishing or a fake social media campaign.

Educating the End User

- Training outcomes
 - All users should acknowledge that they successfully finalized the training.
 - All users are aware about the security threats and countermeasures covered in the training.
 - All users are also aware about the consequences of not following the company's security policy.

Educating the End User

- The problem of BYOD (Bring Your Own Device)
 - Many users will be using their own device to access company information and **they are easy targets for hackers**. If hackers are able to compromise the user's system, they are very close to gaining access to the company's data, since most of the time they are not isolated.
 - Ideally, BYOD should not be allowed in some environments where maximum confidentiality is required. However, enforcing this takes a great deal of time and effort.

Educating the End User

- Social media guidelines for users
 - Many cases were examined that **social media plays an important role in social engineering attacks.**
 - The security program must be in line with HR and legal requirements regarding how the company should handle social media posts, and also give guidelines to employees on how they should handle their own social media presence.
 - One of the tricky questions while defining a set of guidelines to employees on how to use social media is the definition of appropriate business behaviour. Disciplinary action against employees that crosses this boundary should be very clear.

Educating the End User

- Dealing with defamatory and inappropriate posts
 - There should be guidelines to deal with defamatory posts, as well as pornographic posts, proprietary issues, harassment, or posts that can create a hostile work environment.
 - These are imperative for most social media guidelines, and it shows that the employer is being diligent in promoting a wealth social environment within the company.

Policy Enforcement

- Policy enforcement based on a network architecture diagram
 - Understand fully:
 - ✓ what the **endpoints** are;
 - ✓ what **servers** an organization has;
 - ✓ how the information flows;
 - ✓ where the information is stored;
 - ✓ who has and who should have data access.
 - *Many companies fail to enforce policies fully because they only think of enforcing policies at endpoints and servers.*
- Policy enforcement on network devices
 - A holistic approach is needed to tackle every single component that is active in the network, including switches, printers, and IoT devices.

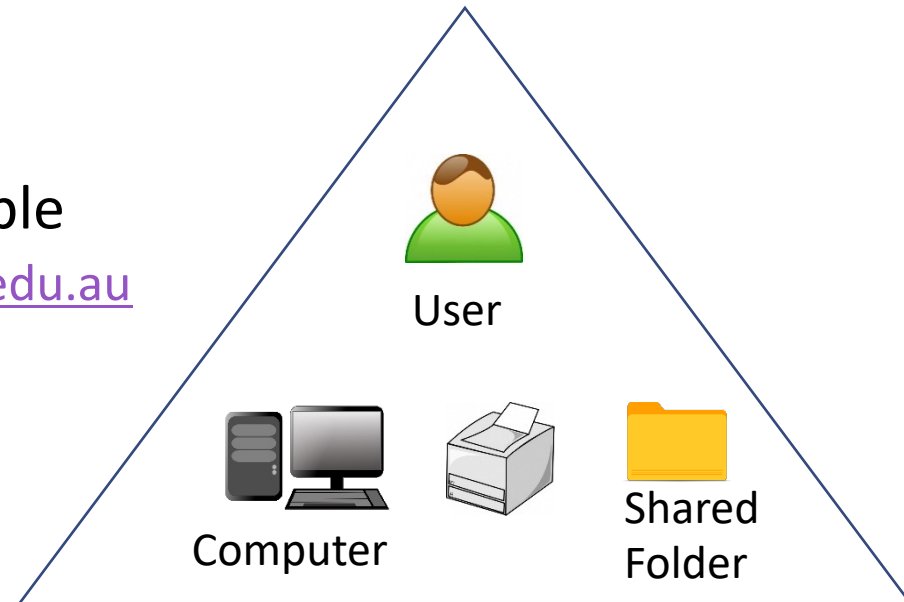
Preliminary: Active Directory

- Purpose

- To arrange all the network objects including users, computers and other items into logical and hierarchical structure.
- To provide authentication and authorization for those (users, computers and other items).

- “Objects” in Active Directory

- Each Object has attributes, for example
 - ✓ User: Partha Sarathi Roy, partha@uow.edu.au
 - ✓ PC: UOW1892-2, SCIT/EIS
 - ✓ Printer: HP1022, Building 3-233
 - ✓ Shared Folder: SCIT_Subject, EIS



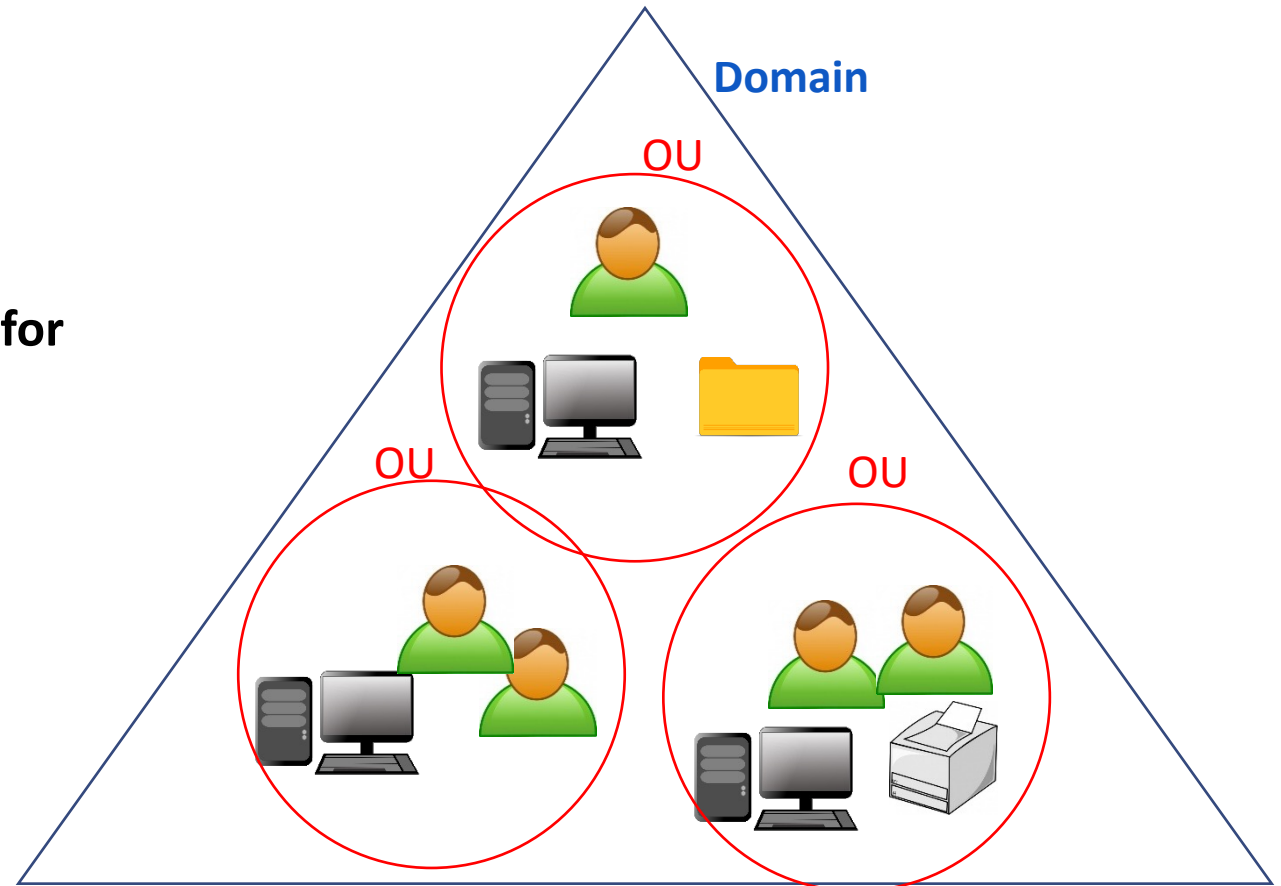
Preliminary: Active Directory

- Structure of Active Directory

- **Domain**: A collection of Objects within Active Directory network.

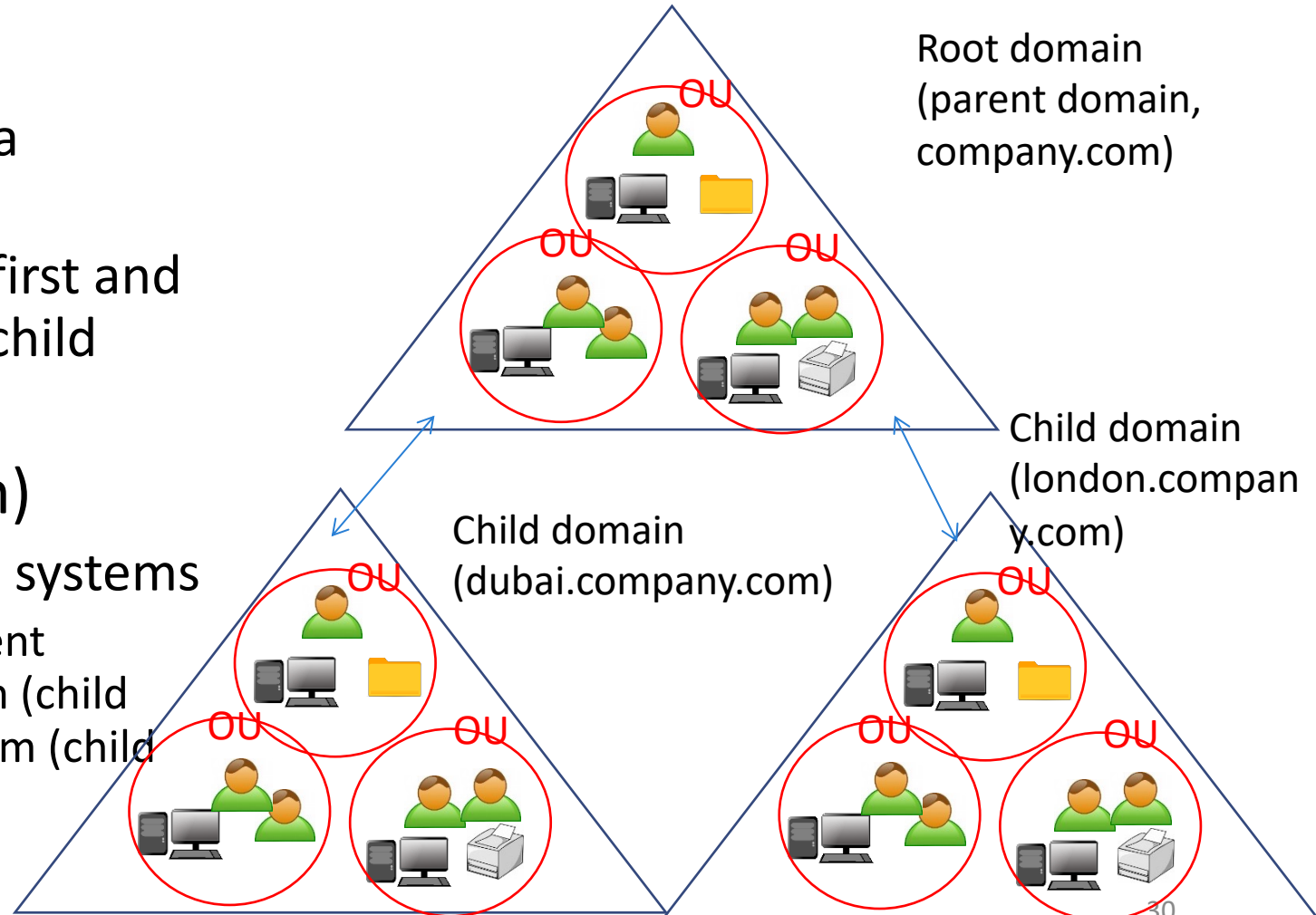
- **OU** (Organizational Units)

- ✓ A subdomain which is a **container for Objects**.
 - ✓ Using OUs, an administrator can create hierarchy that reflects the structure of the organization.



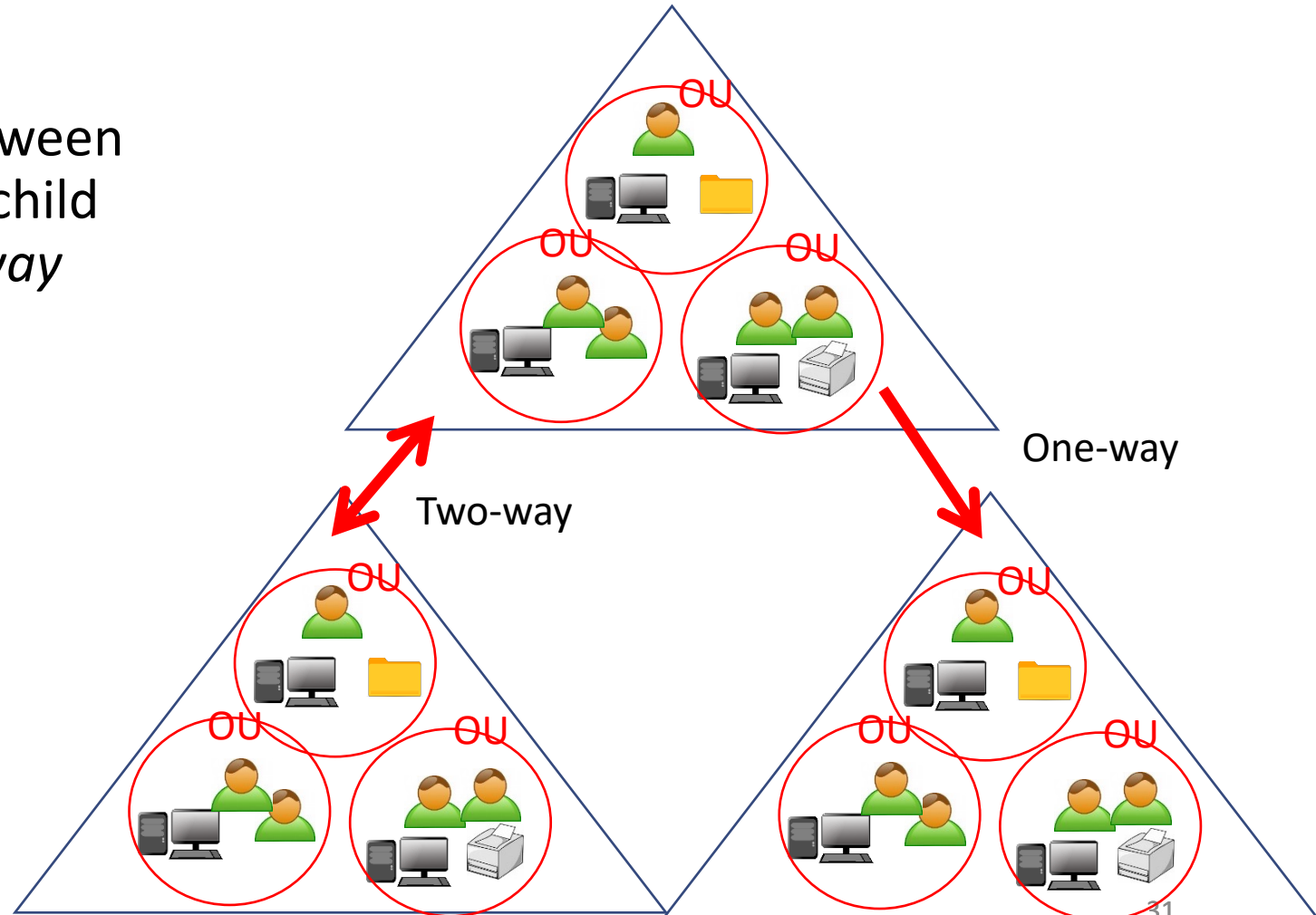
Preliminary: Active Directory

- Domain tree
 - Multiple domains can form a domain tree.
 - The root domain is created first and serves a parent domain for child domains.
- DNS (Domain Name System)
 - Hierarchical domain naming systems
 - ✓ Example: company.com (parent domain), dubai.company.com (child domain), london.company.com (child domain)



Preliminary: Active Directory

- Trust relationship
 - The default relationship between the parent domain and the child domain is a *transitive two-way* trust.
 - Other types are possible depending using
 - ✓ One-way trust
 - ✓ Non-transitive two-way trust



Preliminary: Active Directory

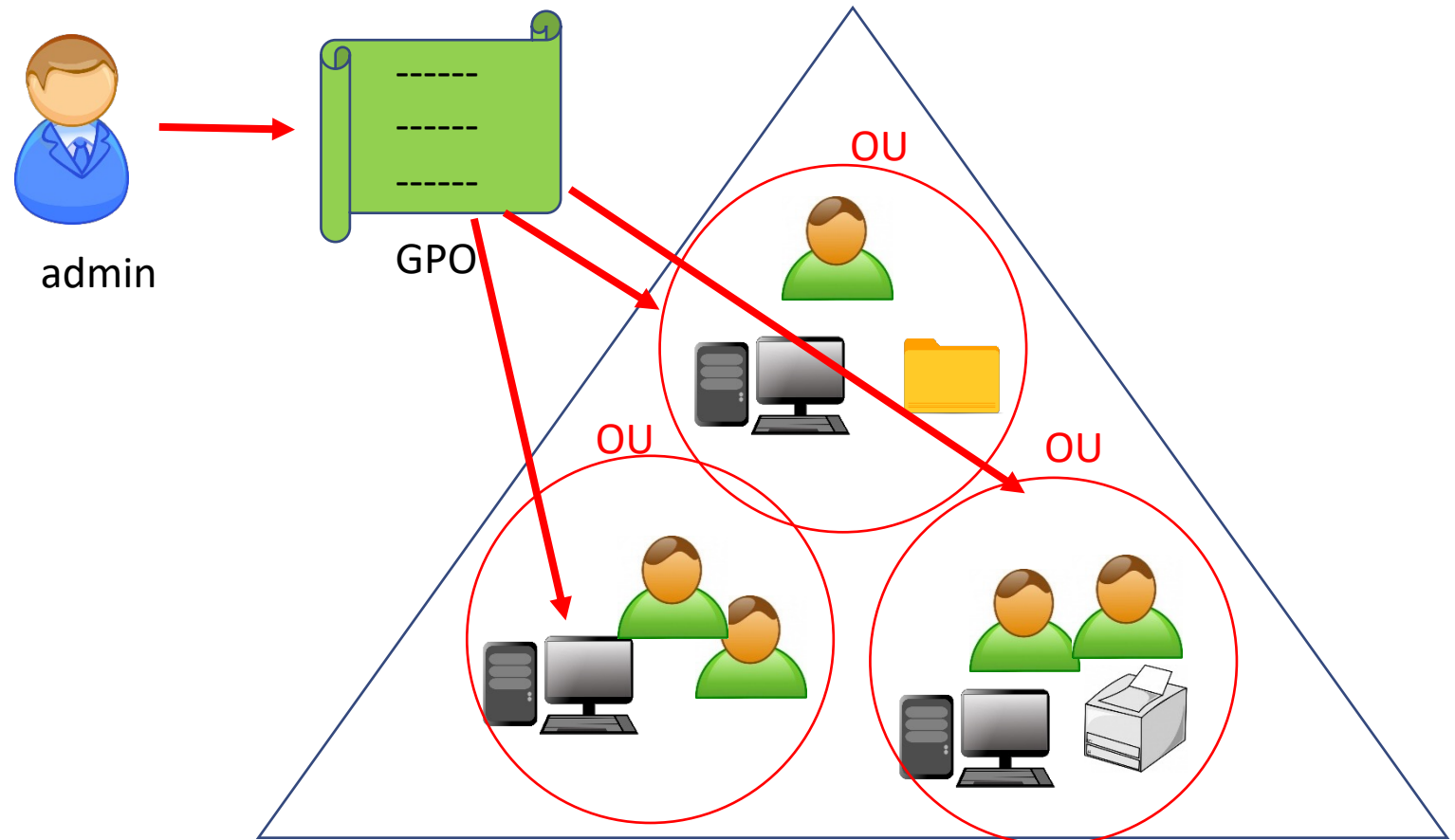
- Group Policy

- **Group Policy** is a feature (of the Microsoft Windows NT family of operating systems) that centrally controls the working environment of user accounts and computer accounts.
- It was created to overcome the problem with the Windows registry
 - ✓ Registry is similar to a login script that stores program and system settings.
 - ✓ A change in registry is permanent. If the user has a new job title, a different registry is needed.
 - ✓ *Group policy makes this change easy*: Group policy is able to reverse any previous configuration made for that user.
 - ✓ The administrator only needs to worry about configuring the required changes.

Preliminary: Active Directory

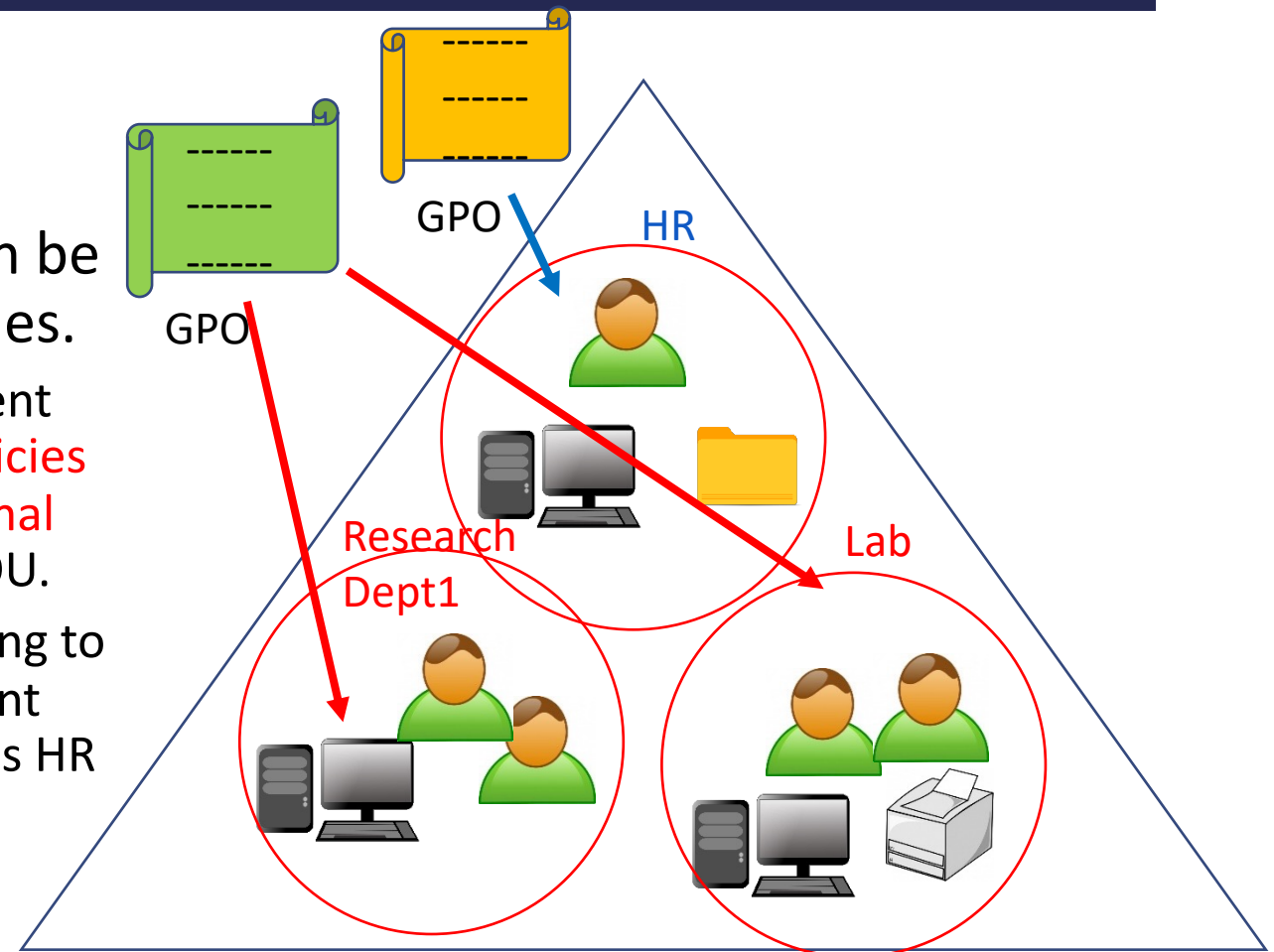
- Execution of Group Policy

- Group Policy Object (GPO): **A collection of settings that define what a system will look like and how it will behave for a defined group of users.**
- The admin distributes GPO through Active Directory to servers and users in OUs.



Policy Enforcement

- A tool for policy enforcement: Microsoft Active Directory
 - The **Group Policy Object (GPO)** can be leveraged to deploy security policies.
 - ✓ If different departments have different needs, **the deployment of group policies can be segmented using organizational units (OUs)** and assign policies per OU.
 - ✓ For example, if the servers that belong to the HR department require a different set of policies, a custom policy to this HR OU should be assigned.



Policy Enforcement

- **Important Group Policy settings for preventing security breaches**

1. Set limits on a computer's Control Panel
 - ✓ This is to prevent non-admin user from modifying system configurations.
2. Prevent Windows from storing LAN Manager Hash
 - ✓ This is to *prevent pass-the-hash attack*.
3. Control access to Command Prompt
 - ✓ Command Prompts can be used to run commands that give high-level access to users and evade other restrictions on the system. So it is wise to disable Command Prompt.
4. Disable forced systems restarts
 - ✓ This is to prevent important settings and unsaved work from being lost.
5. Disallow removable media drives (DVDs and CDs)
 - ✓ Removable media drives are very prone to infection, and they may also contain a virus or malware.

Policy Enforcement

6. Restrict software installations

- ✓ This is to prevent unwanted apps that have potential to compromise the system from being installed.

7. Disable guest account

- ✓ Sometimes, attackers can use Guest account to access your computer.

8. Set minimum password length to higher limits

- ✓ Recommendations: Admin password: at least 15 characters; Regular user password: at least 12 characters

9. Set maximum password age to lower limits

- ✓ Recommendation: 42 days

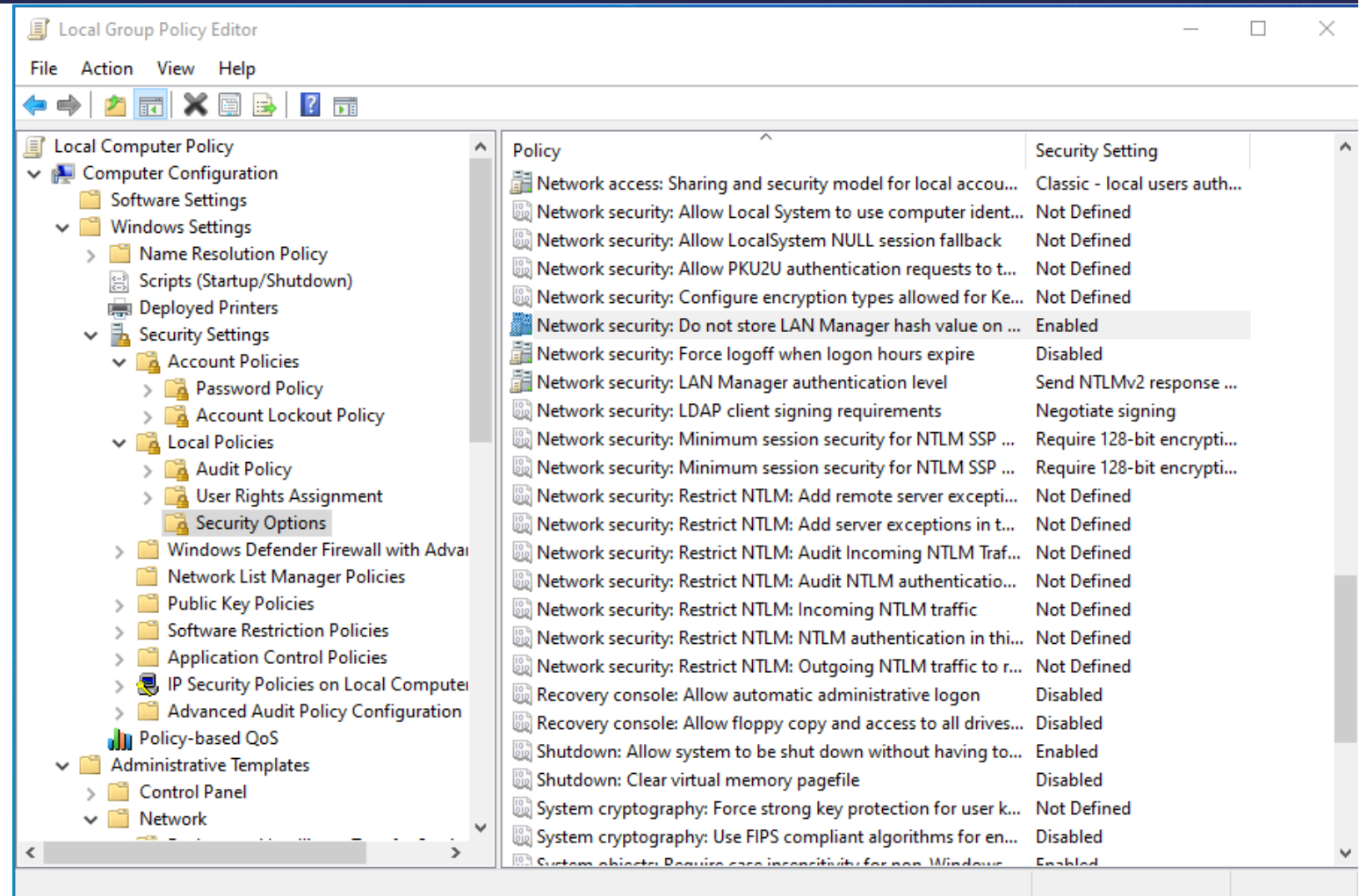
10. Disable Anonymous SID (Security IDentifier) enumeration

- ✓ In older versions of Windows, users could query the SIDs to identify important users and groups.

Policy Enforcement

- Example settings
 1. Prevent Windows from storing LAN Manager Hash

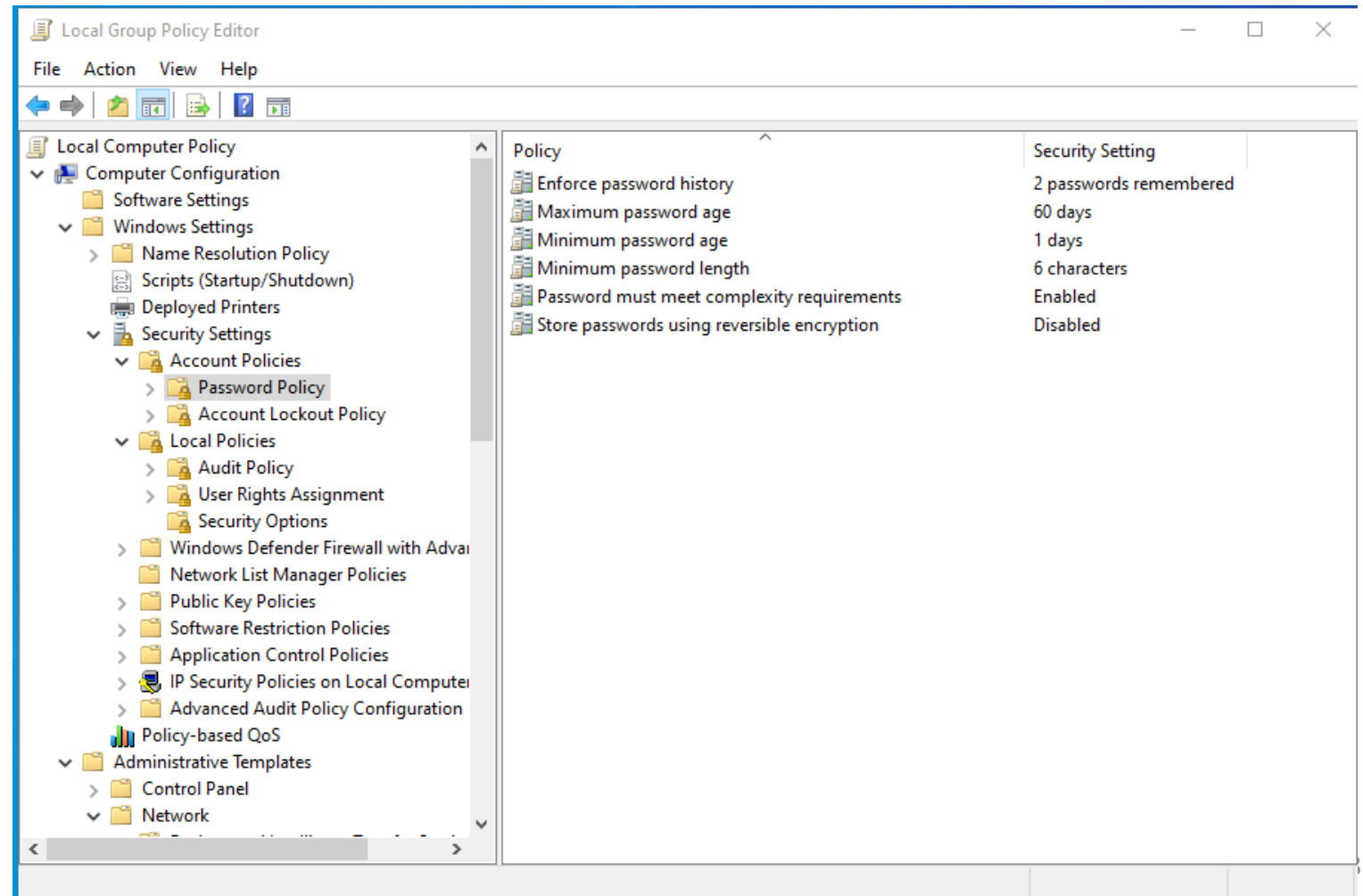
Group policy setting of Partha's machine →



Policy Enforcement

- Example settings
8. And 9. Password
length and age

Group policy setting of
Partha's machine →



Policy Enforcement

- Application whitelisting
 - Usually organization's security policy dictates that **only licensed software is allowed to run in the user's computer.**
 - Running unlicensed software should be prevented and the use of licensed software that is not authorized by IT should be restricted.
 - Policy enforcement ensures that only authorized applications will run on the system.
 - NIST guidance on application whitelisting - Publication 800-167:
<http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-167.pdf>

ISO27001, NIST Cybersecurity Framework

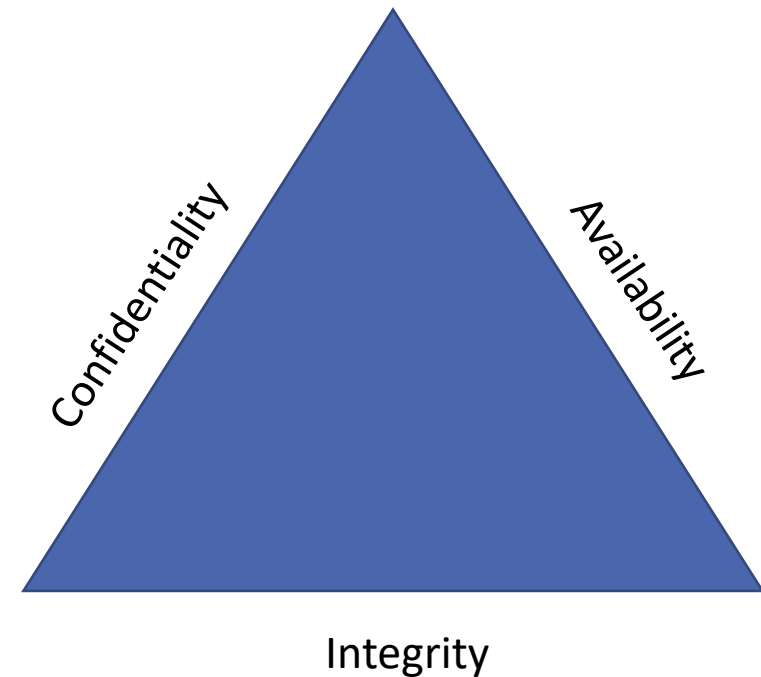


ISO 27001: Information Security Management Framework

- ISO/IEC 27001 – Information technology — Security techniques — Information security management systems — Requirements.”
- The purpose of ISO 27001 framework
 - ISO framework is a combination of policies and processes for organisations to use.
 - ISO 27001 provides a framework to help organisations of any size or any industry to protect their information in a systematic and cost-effective way through an Information Security Management System (ISMS).
- Original version published in 2005, revised in 2013 and 2017.

ISO 27001: Information Security Management Framework

- The basic goal of ISO27001: To protect three aspects of information, which are
 - Confidentiality
 - ✓ Keep information secret/private from those who are not authorised
 - Integrity
 - ✓ Keep information in a format that retains its original purpose and meaning
 - Availability
 - ✓ Keep information and resources available to those legitimate



ISO 27001: Information Security Management Framework

- Information Security Management Systems (ISMS): A set of rules that an organisation needs to establish the following:
 - Identifying stakeholder's expectations of the company in terms of information security
 - Identifying which risks exist for the information security
 - Defining controls and other mitigation methods to meet the identified expectations and handle risks
 - Setting clear objectives on what needs to be achieved with information security
 - Implementing all the controls and other risk treatment methods

ISO 27001: Information Security Management Framework

- Continuously measuring if the implemented controls perform as expected
- Making continuous improvement to make the whole ISMS work better

ISO 27001: Information Security Management Framework

- Reasons for requiring ISMS

- Comply with legal requirements

- ✓ Implementing ISO27001 can resolve most of the requirements of laws, regulations and contracts regarding information security.

- Achieve competitive advantages

- ✓ An organisation certified by ISO27001 is more competitive compared with other organisations.

- Lower costs

- ✓ Preventing security incidents from happening will enable an organisation (company) to save much money.

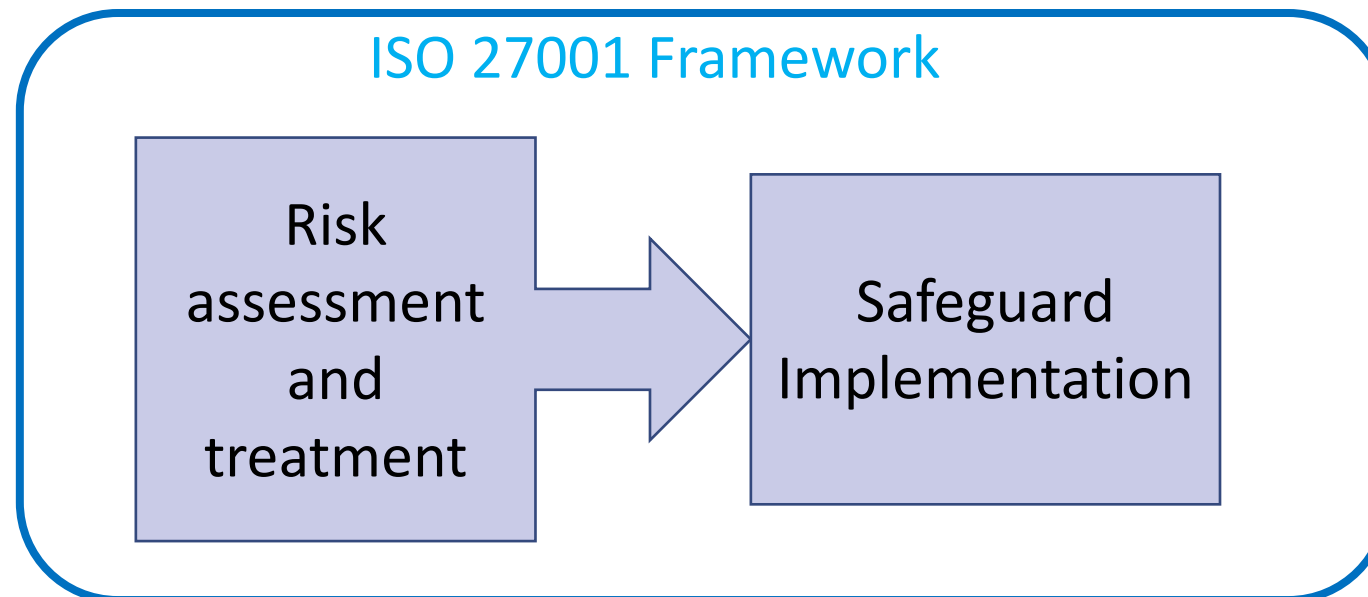
- Better organisation

- ✓ ISO27001 helps a company set up procedures and processes for information security easily.

ISO 27001: Information Security Management Framework

- The functionality of ISO27001

- The main functionality of ISO 27001 is to manage risks by finding out where the risks are, and then systematically treating them, through the implementation of security controls (or safeguards).



ISO 27001: Information Security Management Framework

- 14 Domains of ISO27001

Information security policies	Operations security
Organization of information security	Communications security
Human resources security	System acquisition, development and maintenance
Asset management	Supplier relationships
Access control	Information security incident management
Cryptography	Information security aspects of business continuity management
Physical and environmental security	Compliance

ISO 27001: Information Security Management Framework

- Implementing 114 controls of ISO27001 involve the following areas:
 - Technical controls
 - ✓ E.g. backup, antivirus software, etc.
 - Organisational controls
 - ✓ E.g. access control policy, BYOD policy
 - Legal controls
 - ✓ E.g. NDA (non-disclosure agreement), SLA (service level agreement)
 - Physical controls
 - ✓ E.g. CCTV cameras, alarm systems, locks, etc
 - Human resource controls
 - ✓ E.g. security awareness training, ISO 27001 auditor training

NIST Cybersecurity Framework

- National Institute of Standards and Technology Cybersecurity Framework (NIST CSF)
 - It is a set of guidelines and best practices to help organizations build and improve their cybersecurity posture.
 - ✓ The framework puts forth a set of recommendations and standards that enable organizations to be better prepared in identifying and detecting cyber-attacks, and also provides guidelines on how to respond, prevent, and recover from cyber incidents.
 - It is considered as an essential standard for building up a cybersecurity program.
 - Version 1.0 published in 2014, Version 1.1 published in 2018.

NIST Cybersecurity Framework

- Five core functions of NIST CSF

- Identify

- ✓ Recognising processes and assets that need protection

- Protect

- ✓ Implementing appropriate safeguards to ensure the protection of the enterprise's assets

- Detect

- ✓ Implementing appropriate mechanisms to identify the occurrence of cybersecurity incidents

- Respond

- ✓ Developing techniques to contain the impacts of cybersecurity events

- Recover

- ✓ Implementing appropriate process to restore capabilities and services impaired due to cybersecurity events

Vulnerability Management & Implementing Vulnerability Management



Overview: Vulnerability Management

- Creating a vulnerability management strategy
- Vulnerability management tools
- Implementing vulnerability management
- Best practices for vulnerability management

Creating Vulnerability Management Strategy

- Benefits of having **vulnerability management strategy**
 - The vulnerability management strategy will enable an organization to schedule all vulnerability mitigation processes in an orderly way.
 - In particular, the targets and victims of cybersecurity incidents will be able to mitigate the damage that they have incurred or might incur.
 - *The right counteractions* are scheduled to be performed *at the right time* to find and address vulnerabilities before attackers can abuse them.

Creating Vulnerability Management Strategy

- Five distinct phases of the vulnerability management strategy

Phase 1: Creating asset inventory

Phase 2: Planning information management

Phase 3: Performing *risk assessment* (There are sub phases)

Phase 4: Reporting and remediation tracking

Phase 5: Response planning

Creating Vulnerability Management Strategy

Phase 1: Creating **asset inventory**

- An asset inventory is a list that security administrators can use to go through the devices an organization has and highlight the *ones that need to be covered by security software*.
- A small number of employees are responsible for managing an asset inventory to ensure that all devices are recorded and that the inventory remains *up-to-date*.
- The asset inventory is also a great tool that network and *system admins can use to quickly find and patch devices and systems*.

Creating Vulnerability Management Strategy

- The consequence of not having proper inventory:
 - ✓ Some devices could be left behind when new security software is being patched or installed.
 - ✓ The organization may underspends or overspends on security. This is because it cannot correctly determine the devices and systems that it needs to purchase protection for.
- The challenges
 - ✓ Poor change management.
 - ✓ The lack of effective tools for maintaining the inventory in a consistent manner.

Creating Vulnerability Management Strategy

Phase 2: Planning **information management**

- To plan **how to control information flows** into an organization.
- *Network security*: Attention should be paid to this *information flow* to prevent threats from getting in or out of a network.
- *Data security*: Some of organization's data must never be accessed by the attackers.
 - ✓ Information, such as trade secrets and the personal information of customers, could cause irreparable damage if it is accessed by hackers.
 - ✓ An organization may lose its reputation, and could also be fined huge sums of money for failing to protect user data. (Competing organizations could get secret formulas, prototypes and business secrets.)

Creating Vulnerability Management Strategy

- Computer security incident response team (CSIRT): In order to achieve network and data security, an organization could deploy this team to handle any threats to its information storage and transmission.
- **The policy of least privilege ("need-to-know"):** This policy ensures that users are denied access to all information apart from that which is necessary for them to perform their duties.
- End user devices: Measures should be put in place on end user devices to prevent the illegal copying or reading of data.

Creating Vulnerability Management Strategy

Phase 3: Performing **risk assessment**

- The security team should do an in-depth analysis of the vulnerabilities that it faces.
- In this step, an organization has to prioritize some vulnerabilities over others and allocate resources to mitigate against them.
- Risk assessment is comprised of the following Six stages.
 - ✓ Stage 3-1) Scope identification
 - ✓ Stage 3-2) Collecting data
 - ✓ Stage 3-3) Analysis of policies and procedures
 - ✓ Stage 3-4) Vulnerability analysis
 - ✓ Stage 3-5) Threat analysis
 - ✓ Stage 3-6) Analysis of acceptable risks

Vulnerability Management Tools

- Asset inventory tools
 - The asset inventory tools are aimed at recording the computing assets that an organization has so as to ease their tracking when it comes to performing updates (e.g., Peregrine tools, LANDesk Management Suite and StillSecure).
- Information management tools
 - The information management tools are used to disseminate information about intrusions and intruders to the right people who can take the recommended actions.
 - There are a number of tools that offer solutions to dissemination of information in organizations through emails, websites and distribution lists (e.g., CERT Coordination Center, Security Focus and Symantec Security Response).
 - The mailing lists can be set up so that incident responders get the alerts first, and once they have verified a security incident, the rest of the users can be informed.

Vulnerability Management Tools

- Risk assessment tools

- Most risk assessment tools are developed **in-house** since all organizations do not face the same risks at the same time.
- There are many variations in risk management, and that is why it might be tricky to use only one choice of software as the universal tool to identify and assess the risks that an organization users.
- The in-house tools that organizations use are checklists developed by the system and network administrators.
 - ✓ The checklist should be made up of questions about potential vulnerabilities and threats that the organization is exposed to.
 - ✓ These questions will be used by the organization to define the risk levels of the vulnerabilities identified within its network.

Vulnerability Management Tools

- A set of questions that can be put on the checklist:
 - ✓ How can the identified vulnerabilities impact the organization?
 - ✓ Which business resources are at risk of being compromised?
 - ✓ Is there a risk for remote exploitations?
 - ✓ What are the consequences of an attack?
 - ✓ Is the attack reliant on tools or scripts?
 - ✓ How can the attack be mitigated?
- To complement the checklist, organizations can acquire commercial tools that perform automated risk analysis such as ArcSight Enterprise Security Manager (ESM).

Vulnerability Management Tools

- Vulnerability analysis tools

- The two most commonly used vulnerability scanners are Nessus and Nmap (the latter of which can be used as a basic vulnerability tool via its scripting function).
 - ✓ Nmap quickly maps a new network and provides information about the assets connected to it and their vulnerabilities.
 - ✓ Nessus can perform an in-depth vulnerability assessment of the hosts connected to a network. The scanner will be able to determine their operating systems versions, missing patches, and the relevant exploits that can be used against the system. The tool also sorts the vulnerabilities according to their threat levels.

Vulnerability Management Tools

- Reporting and remediation tracking tools
 - There are many stakeholders in an organization and not all of them can understand technical jargon. At the same time, the IT department wants tools that can give them the technical details without any alterations. Therefore, the separation of audiences is important.
 - Here are the tools used in this stage: Foundstone's Enterprise Manager and the Latis Reporting tool
 - ✓ They have similar functionalities.
 - ✓ They both provide reporting features that can be customized to the different needs of users and other stakeholders.

Vulnerability Management Tools

- Response planning tools

- Response planning is the step where most of the resolution, eradication, cleansing and repair activities take place.
- Patches and system upgrades also occur at this stage. There are not many commercial tools made to facilitate this step.
- Mostly, response planning is done through **documentation**.
 - ✓ Documentation helps system and network administrators with the patching and updating process for systems that they are not familiar with.
 - ✓ It also helps during changeovers where new staff may be put in charge of systems that they have never used before.
 - ✓ Documentation helps in emergency situations to avoid skipping some steps or making mistakes.

Common Vulnerabilities and Exposures

- Common Vulnerabilities and Exposures (CVE)

- Provides a catalog for publicly known information security vulnerabilities and exposures
- It is supported by US-CERT, US Homeland Security Department and MITRE
- Definitions given in CVE:
 - ✓ **Vulnerability**: The state of being exposed to an attacker who can maliciously gain full access to a network or system
 - ✓ **Exposure**: A mistake in software code or configuration that provides an attacker with indirect access to a network or system

Common Vulnerabilities and Exposures

- **Purpose of CVE:**

- To standardize the way each known vulnerability and/or exposure is identified: CVE database is maintained
- Standard IDs provides security administrators with quick access to technical information about a specific threat across multiple CVE-compatible information sources

Common Vulnerabilities and Exposures

- Each entry in the CVE database consists of
 - CVE-ID: The actual CVE identifier, i.e. CVE-2012-2234. Note that the general syntax is CVE + Year + Arbitrary Digits
 - Description: Text description of the issue (or placeholder when the issue is under embargo)
 - References: URLs and other information for the issue
 - Date Entry Created: The date the entry was created
 - Phase/Votes/Comments/Proposed The CVE database can be searched by downloading the master copy from <http://cve.mitre.org/data/downloads/index.html>

Best Practices for Vulnerability Management

- Best practice for creating asset inventory
 - **The organization should establish a single point of authority.** There should be one person (or one group) that can be held responsible if the inventory is not up to date or has inconsistencies.
 - Another best practice is *to encourage the use of consistent abbreviations during data entry*. It may become confusing to another person trying to go through the inventory if the abbreviations keep on changing.
 - The inventory should also be *validated at least once a year*.

Best Practices for Vulnerability Management

- Best practice for the information management
 - One of the best methods for a fast and effective dissemination of information to the relevant audience is allowing employees to **make the conscious effort of subscribing to mailing lists**.
 - Another one is to allow the incident response team *to post its own reports, statistics and advice on a website for the organization's users*.
 - ✓ The organization should also hold periodic conferences to discuss new vulnerabilities, virus strains, malicious activities, and social engineering techniques with users.
 - The organization should come up with ***a standardized template of how all the security-related emails*** will look. It should be a consistent look that is different from the normal email format that users are used to.

Best Practices for Vulnerability Management

- Best practice for the risk assessment
 - One of the best practices is to document the ways to ***review new vulnerabilities as soon as they appear.***
 - Another best practice is to *publish the risk ratings to the public or at least to the organizational users.*
 - Ensure that asset inventories are both available and updated at this stage so that *all hosts in a network can be treated during risk assessment.*
 - Ensure that it has *a strict change management process* so that incoming staff are made aware of the security posture of the organization and the mechanisms in place to protect it.

Best Practices for Vulnerability Management

- Best practice for the vulnerability analysis
 - *Seek permission before extensively testing the network.* This is because this step might introduce serious disruptions to an organization and might do actual damage to the hosts. Therefore, a lot of planning ahead needs to happen.
 - Identify the ***scanning tools*** that are best for its hosts. Some methods may be overkill where they do too much scanning and to an unnecessary depth. Other tools are too shallow and do not discover the vulnerabilities in a network.

Best Practices for Vulnerability Management

- Best practice for reporting and remediation tracking stage.
 - *Ensure that there is a reliable tool for sending reports to asset owners* concerning the vulnerabilities they had and whether they have been fixed completely.
 - The *incident response team* should also agree with the management of the remediation time frames and the required resources and make known the consequences of non-remediation.
 - Remediation should be performed following *the **hierarchy of severity***.